EASTERN MICHIGAN UNIVERSITY

College of Engineering and Technology

IA 642: Defensive Security

Week 03, Module 02 Lab: Harden and Instrument a Meridian Endpoint

Endpoint Defense & Detection · NUR-CLIN-014 Rebuild

Group members	Unais Ali	**EID**	E02805019
	Hafiz Usama		E02574092
Course	IA 642 Defensive Security	**Week**	3, Lab 3.2
Host	NUR-CLIN-014 (cardiology nurse station)	**Date**	September 2026

Meridian Health Network continues from Lab 2.3 (network boundaries / infusion-pump segmentation). This lab goes inside one of those zones, hardens the rebuilt clinical workstation NUR-CLIN-014, and writes Endpoint Detection and Response (EDR) detections for the attacker behaviors recovered from the old build. It is separate from the Week 02 university payment TARA case.

1. Part A: Fork and Baseline

Question	Answer
Fork	**Windows** (Windows 11 Enterprise workstation image for shared nurse-station use).
Published baseline	**CIS Microsoft Windows 11 Enterprise Benchmark**, Level 1 (Workstation profile).
Why this baseline	Meridian is a civilian healthcare provider, not a DoD system, so CIS Level 1 matches the EHR/imaging/e-prescribing role without STIG operational cost that 24/7 shared stations cannot absorb.
MAC / application-control mechanism	**Windows Defender Application Control (WDAC)** (AppLocker only as legacy audit during cutover).

The lecture's five control goals are the same on every OS; only the mechanisms change. Figure below places Windows and Linux side by side. NUR-CLIN-014 answers the **Windows** column (WDAC, Credential Guard / LSASS, NTFS ACLs, least-privilege services, CIS Windows 11 Enterprise L1). SELinux / AppArmor would apply only if Meridian had forked Linux.

NIST SP 800-53 mapping (why this endpoint program exists). This lab covers the three families named in the module slide:

Control	Family	How NUR-CLIN-014 answers it
CM-6	Configuration Settings	CIS Windows 11 Enterprise Level 1 hardening baseline + Part B control table (WDAC, Credential Guard, NTFS ACLs, service identities, logging).
SI-3	Malicious Code Protection	WDAC allowlisting plus EDR response actions that block or alert on unauthorized execution (Run-key implants, side-loaded DLLs, LOLBAS downloaders).
SI-4	System Monitoring	Part D detection logic: Sysmon/EDR telemetry, ATT&CK-mapped rules, LSASS ProcessAccess detection, and Part E sensor heartbeat so monitoring does not go silent.

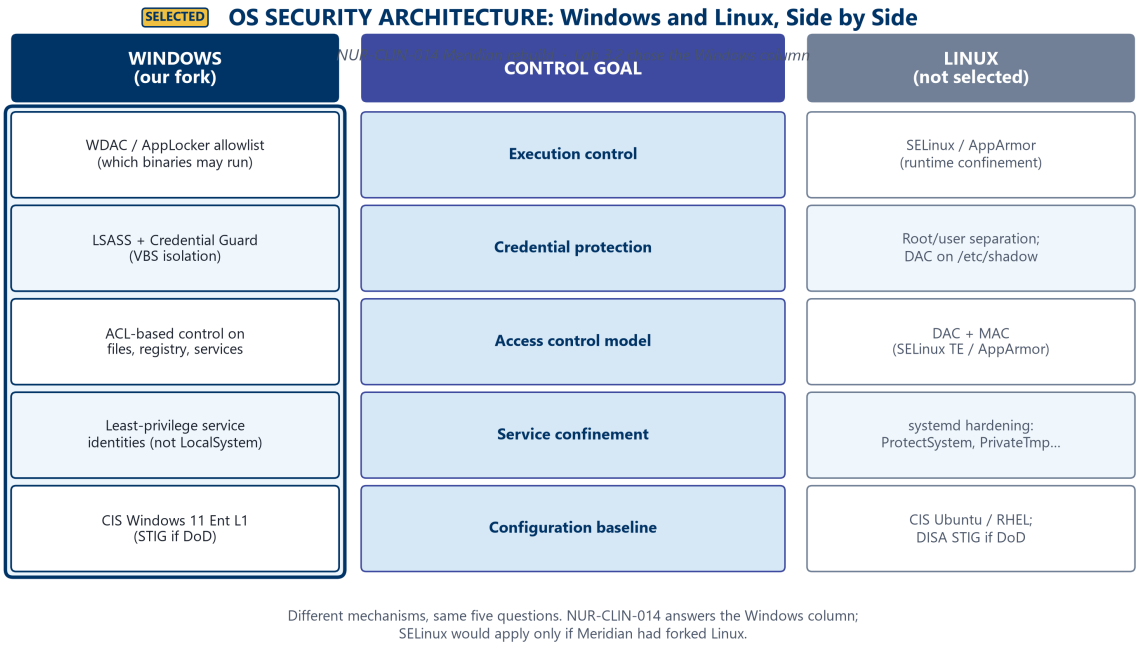


Figure 1. Author-created Windows vs. Linux security-architecture map for Meridian NUR-CLIN-014 (same five goals as the course slide; this rebuild uses Windows).

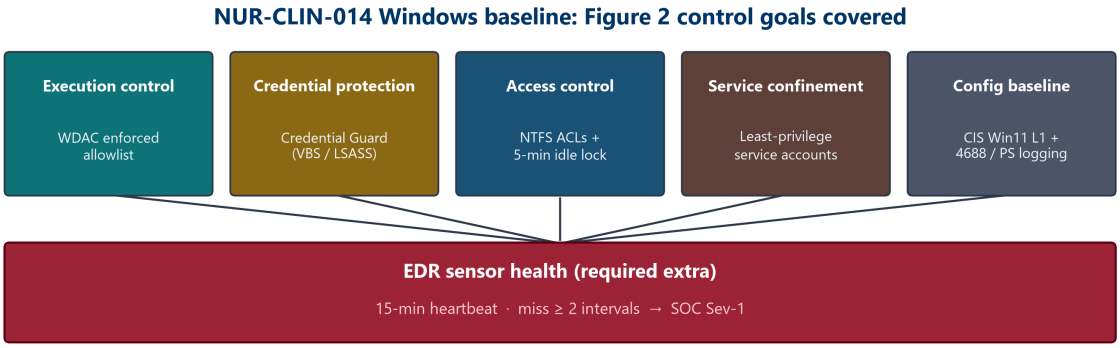


Figure 2. Author-created map of how the NUR-CLIN-014 Windows baseline answers each Figure 2 control goal, plus EDR sensor health.

Hardening alone is not enough. Figure below is Meridian's seven-layer endpoint defense stack for this rebuild: Layers 1-5 harden; Layers 6-7 detect and respond. An attacker must defeat every layer and stay invisible to the last two.

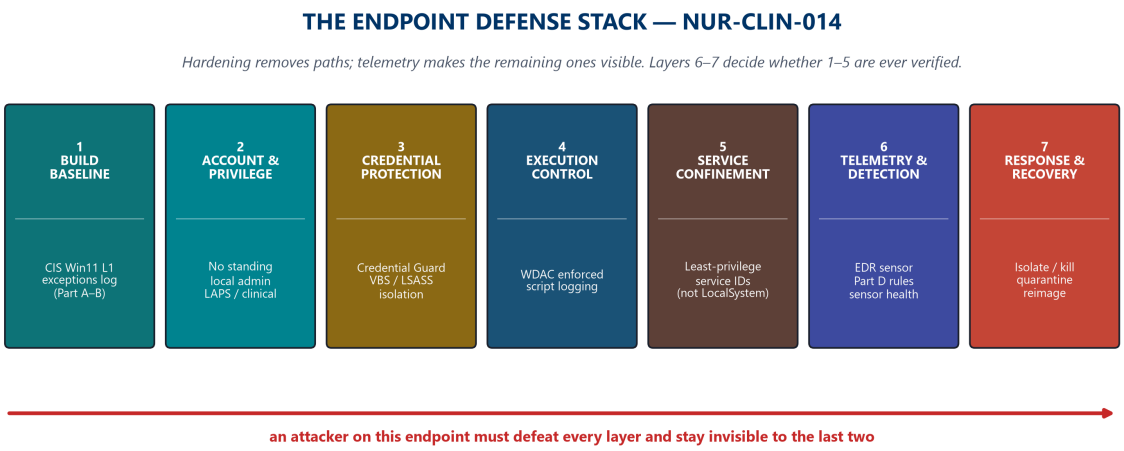


Figure 3. Author-created endpoint defense stack for NUR-CLIN-014 (Build baseline to Response and recovery), mapped to Lab 3.2 Parts A-E.

2. Part B: Hardening Baseline

A baseline applied once and never re-measured is a historical document. Figure below is Meridian's lifecycle for NUR-CLIN-014: this lab deliverable completes **Select & Scope** (Part A) and **Tailor & Document** (Step 3 exception log); Apply / Measure / Remediate Drift are the scheduled operations model after the rebuild image is signed.

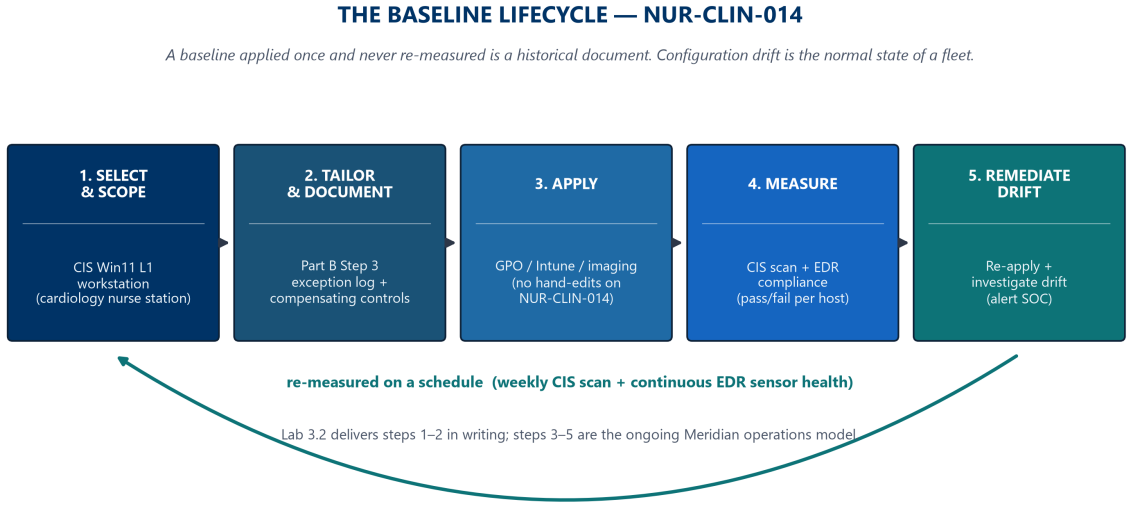


Figure 4. Author-created baseline lifecycle for NUR-CLIN-014 (Select → Tailor → Apply → Measure → Remediate Drift, re-measured on a schedule).

Step 2: Baseline control table

All five Figure 2 goals plus EDR sensor health are covered. Credential protection isolates LSASS secrets with Credential Guard (VBS). The lab handout Administrators-group worked example is **not** reused.

#	Setting / Control	Value	Control Goal	Risk It Closes
1	WDAC Code Integrity policy (enforced)	Allow Microsoft-signed OS binaries, Meridian-signed clinical packages, approved browser; deny user-writable paths	Execution control	Blocks unsigned payloads from temp dirs (old Run-key implant path).
2	Credential Guard (VBS isolation of LSASS)	Enabled; require UEFI Secure Boot + virtualization so LSASS credential material runs in a protected enclave	Credential protection	Stops reusable LSASS secrets from being dumped for lateral movement.

#	Setting / Control	Value	Control Goal	Risk It Closes
3	NTFS ACLs on clinical app folders (C:\Program Files\Meridian*)	Clinical users: Read & execute only; Modify/Write denied; SYSTEM + named workstation-admins: Full	Access control model	Stops a nurse account from replacing EHR/imaging binaries or dropping side-load DLLs.
4	Service account identity for vendor helpers	No clinical service as LocalSystem unless vendor-documented; else least-privilege / gMSA	Service confinement	Limits blast radius of T1543-class service persistence.
5	PowerShell / script logging	Module + Script Block Logging + Transcription on; Constrained Language Mode for standard users	Configuration baseline	Makes living-off-the-land script staging visible to EDR.
6	Process Creation auditing (4688) + command line	Audit success; Include command line in process creation events = Enabled	Configuration baseline	Supplies command-line telemetry for Part D detections.
7	Interactive logon: machine inactivity limit	5-minute idle lock; badge/PIN re-auth on shared station	Access control	Reduces corridor walk-up session hijack.
8	EDR sensor health / heartbeat policy	Check-in every 15 min; miss ≥2 intervals = critical SOC ticket	EDR sensor health	Prevents another 41-day silent-agent window.
9	Windows Security event log retention	Security log ≥1 GB; clearing Security log = high-severity SIEM alert	Configuration / visibility	Makes T1070.001 log clearing immediately visible.

Step 3: Exception log

Baseline Item Not Applied	Operational Reason	Compensating Control
Full WDAC block of cardiology imaging viewer plug-in DLLs outside Microsoft catalog	Vendor states viewer fails under pure Microsoft-only allowlist; cardiology cannot wait mid-encounter	Publisher/hash allowlist for signed vendor package path; EDR alert if viewer loads from non-standard parent or user-writable path.
Disabling the browser entirely	E-prescribing and selected EHR workflows need an approved Chromium browser	WDAC allows only managed browser; URL filtering + SmartScreen; extension allowlist by GPO.
Remove local admin accounts entirely	Break/fix imaging and overnight vendor patches may need controlled local elevation if domain is unreachable	LAPS rotates single local admin every 24h; elevations logged/ticketed; no clinical users in Administrators.

3. Part C: ATT&CK Mapping

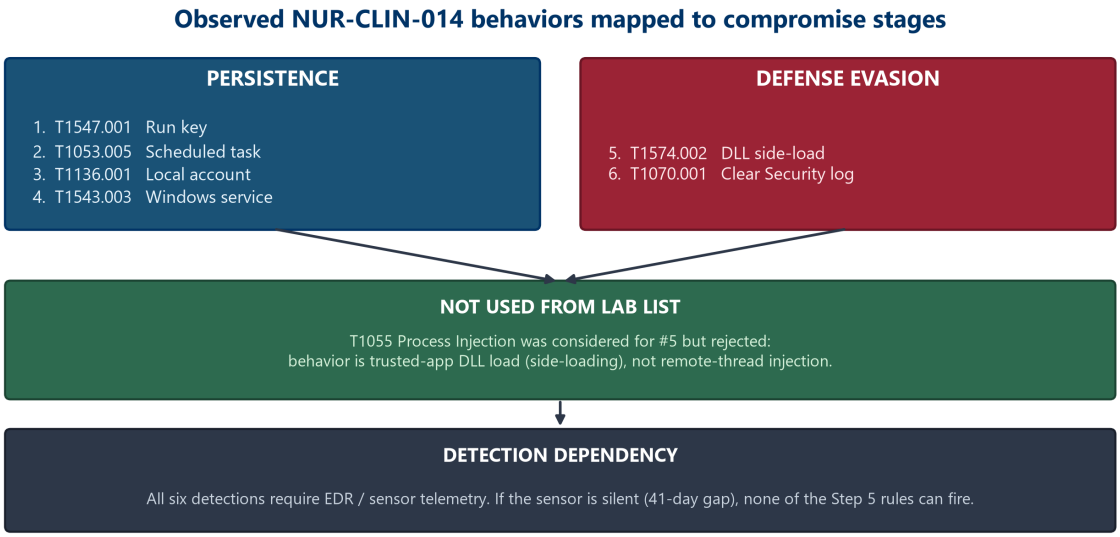


Figure 5. Author-created stage map for the six behaviors. T1055 was considered for #5 and rejected.

#	Observed Behavior	Stage	ID	Technique Name	Why This One
1	Run-key to exe in user-writable temp	Persistence	T1547.001	Boot/Logon Autostart: Registry Run Keys / Startup Folder	Logon autostart via Run key; not a task (T1053) or service (T1543).
2	Scheduled task every 90 minutes	Persistence	T1053.005	Scheduled Task/Job: Scheduled Task	Time-triggered via Task Scheduler; not logon autostart.
3	New local account + local group add	Persistence	T1136.001	Create Account: Local Account	Account creation is the technique; group add is follow-on privilege.
4	New auto-start SYSTEM service	Persistence	T1543.003	Create/Modify System Process: Windows Service	SCM/service persistence, not Run key or task.
5	Signed app loads unexpected library	Defense evasion	T1574.002	Hijack Execution Flow: DLL Side-Loading	Trusted host loads attacker DLL via search order; not T1055 injection.
6	Security event log cleared 02:14	Defense evasion	T1070.001	Indicator Removal: Clear Windows Event Logs	Explicit clearing of Windows Event Log evidence.

4. Part D: Detection Logic

Meridian's EDR pipeline has four stages (figure below): endpoint sensor to continuous telemetry stream to analytics backend (IOC/IOA matching) to response action pushed back to the sensor. Detection quality is bounded by step 1: an event the sensor never collected cannot be matched or acted on. That is why the old NUR-CLIN-014 silent sensor (41 days) broke every downstream rule.

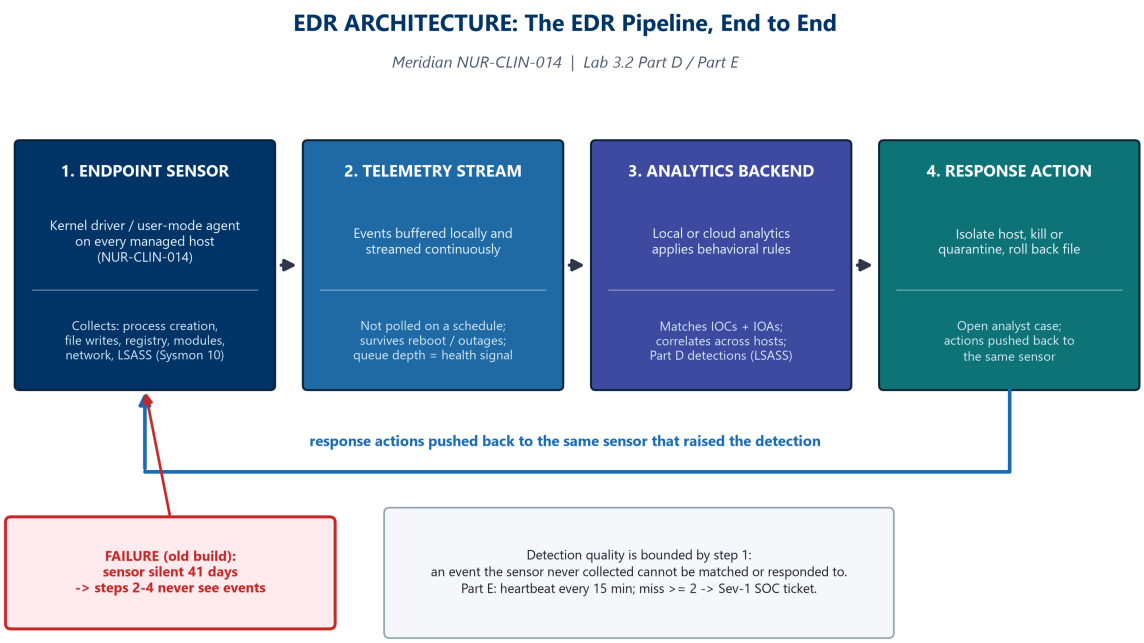


Figure 6. Author-created EDR pipeline for Meridian NUR-CLIN-014 (sensor to stream to analytics to response). Red callout: 41-day silent sensor left steps 2-4 empty.

EDR vs. XDR (scope for this lab). This rebuild instruments **EDR** on NUR-CLIN-014: host telemetry and host response. **XDR** would correlate endpoint plus network, email, identity, and cloud; valuable for Meridian later, but out of scope for a single rebuilt nurse station.

Dimension	EDR (this lab)	XDR (future Meridian)
Named	Gartner / Chuvakin ~2013	Gartner category ~2020
Telemetry scope	Endpoint: processes, files, registry/config, local network	Endpoint + network, email, identity, cloud workloads
Detection unit	Behavior on a single host, correlated across the fleet	Attack chain across different telemetry sources
Response surface	Host actions: isolate, kill, quarantine, roll back	Cross-source: disable account, quarantine message, isolate host
Best at catching	Local execution, persistence, credential access on a host	Chains that look benign in any one source and malicious in sequence

Step 5: Detection logic table

#	ID	Telemetry Required	Detection Logic	Expected False Positive
1	T1547.001	Sysmon 13/14 or registry audit 4657 + image path	Alert when any process writes HKCU/HKLM ...\CurrentVersion\Run (or RunOnce) with ImagePath under %TEMP%, Downloads, or other user-writable path	Installer registering an updater during a change window.
2	T1053.005	Task creation 4698 + task XML/action path	Alert on new scheduled task whose action path is user-writable OR author is a clinical interactive user (not SCCM/Intune)	Endpoint-management patch-night packaging task.
3	T1136.001	Security 4720 + 4732	Alert on local account create outside Meridian naming OR add to Administrators / RDP Users on NUR-CLIN hosts	Ticket-tagged LAPS break-glass workflow.

#	ID	Telemetry Required	Detection Logic	Expected False Positive
4	T1543.003	Service install 7045 / Sysmon + ImagePath	Alert when new auto-start service ImagePath is outside Program Files/Windows, or LocalSystem from user-writable path	Approved vendor imaging service update.
5	T1574.002	Image/library load (Sysmon 7) + signer/path	Alert when allowlisted clinical binary loads DLL that is unsigned, written <24h, or from user-writable directory	Vendor hotfix dropping new signed DLL beside viewer.
6	T1070.001	Security 1102 + EDR sensor event	Critical alert on any Security log clear on clinical workstations; page SOC	Rare Tier-3 rotation with change ticket (still notify).

Additional high-signal rule (not one of the six mapped behaviors; required by the old LSASS-dump finding on NUR-CLIN-014).

#	Focus	Telemetry Required	Detection Logic	Expected False Positive
LSASS	Credential dump / LSASS memory access	Sysmon event 10 (ProcessAccess) to lsass.exe, or equivalent EDR handle-open telemetry (GrantedAccess, SourceImage, TargetImage)	Alert when any process other than known Microsoft/security products opens a handle to lsass.exe with read rights commonly used for credential dumping (e.g., 0x1010, 0x1438, or PROCESS_VM_READ); exclude allowlisted antivirus/EDR binaries by path and signature	Backup agents or security tools that legitimately read LSASS (inventory-all owlisted; unexpected callers still alert).

Step 6: Living off the land

Why allowlisting alone fails. WDAC trusts Microsoft-signed system binaries. LOLBAS documents signed native tools such as certutil.exe, bitsadmin.exe, and mshta.exe that can download or decode a second-stage payload. Because the binary is allowed, the policy never blocks the abuse.

Behavioral detection (not "block certutil"). Alert when certutil.exe or bitsadmin.exe is created with a command line containing -urlcache, -split, -decode, or an http(s) URL, especially when the parent is a browser, Office app, or script host, and the child writes under a user-writable path. Fields: OriginalFileName/Image, CommandLine, ParentImage, TargetFilename, User, UtcTime.

5. Part E: The Silent Sensor

Where EDR does not help. Even a correct Part D rule set fails in four cases. Three of the four applied to NUR-CLIN-014 before Friday morning:

1. **Sensor not reporting**: absent detection (uninstalled, crashed, excluded, stale); the 41-day silence. Sensor health is its own detection surface.

2. **Behavior indistinguishable from administration**: remote execution, scheduled tasks, service creation are also IT work; need role-normal baselines.

3. **Devices that cannot take an agent**: Lab 2.3 infusion pumps still need network segmentation/detection; EDR on NUR-CLIN-014 does not cover them.

4. **Anything nobody triaged**: an alert in an unmonitored queue equals no detection. The pipeline ends with a human, not the alert.

Sensor-health check. Measure EDR agent last-check-in timestamp and sensor service state every 5 minutes from the analytics backend. If a licensed Meridian clinical endpoint misses two consecutive 15-minute heartbeats (or reports ServiceStopped), raise a Sev-1 ticket to SOC Tier 1 and email the clinic IT on-call within 10 minutes. Owner: SOC Tier 1 with escalation to Endpoint Engineering.

Which Step 5 detections still fire if the sensor is silent? None of them, including the additional LSASS handle-open rule. Every detection in Step 5 depends on telemetry the endpoint sensor must collect and transmit. A silent agent means those events never reach the analytics backend, so registry, task, account, service, DLL-load, log-clear, and LSASS ProcessAccess rules cannot alert. Sensor health is therefore a control of its own.

Residual risk the hardened build does not close. Physical shared-station risk remains: a clinician can walk away briefly, or a malicious insider with a valid badge can misuse the EHR client inside WDAC/Credential Guard as a legitimate user. Credential Guard reduces LSASS dump value, but it does not stop an already-authorized clinician from misusing a valid session. Closing that gap needs continuous session analytics, badge/camera correlation, and stricter break-glass auditing. For Meridian-wide chains across email/identity/cloud, EDR alone is also insufficient; that is the XDR gap in Part D.

References

Center for Internet Security. (n.d.). *CIS Benchmarks*. https://www.cisecurity.org/cis-benchmarks

Defense Information Systems Agency. (n.d.). *Security Technical Implementation Guides (STIGs)*. https://public.cyber.mil/stigs/

LOLBAS Project. (n.d.). *Living Off The Land Binaries, Scripts and Libraries*. https://lolbas-project.github.io

MITRE Corporation. (n.d.). *MITRE ATT&CK Enterprise Matrix*. https://attack.mitre.org

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST SP 800-53 Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5